

Task 1: Create an S3 Bucket

Steps

1. Log in to the AWS Management Console.
2. Search for S3.
3. Open the Amazon S3 service.
4. Select Create bucket.
5. Enter a globally unique bucket name.
For example:
swiggy-files-2026-yourname
S3 bucket names must be unique, so if swiggy-files is already taken, add numbers or another unique identifier.
6. Select the desired AWS Region.
7. Keep Block all public access enabled.
8. Leave the remaining settings at their appropriate defaults for this exercise.
9. Select Create bucket.

Upload a File

1. Open the newly created bucket.
2. Select Upload.
3. Select an image or PDF file from your computer.
4. Select Upload.

Task 2: Create a Spotify-Style Folder Structure

Task 3: Create the IAM User zomatoUploader

Step 1: Create IAM User

1. Open the AWS Management Console.
2. Search for IAM.
3. Open IAM.
4. Select Users.
5. Select Create user.
6. Enter:
 - zomatoUploader

7. Configure the authentication method according to the AWS Console's current options and your assignment requirements.
8. Create the user.

Step 2: Create a Custom Permission Policy

Open:

IAM → Policies → Create policy

Select the S3 permissions required for the exercise.

The important permissions are:

s3:ListBucket

s3:PutObject

The policy needs two different resource types because ListBucket applies to the bucket while PutObject applies to objects inside the bucket.

A suitable policy template is:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ListBucket",
      "Effect": "Allow",
      "Action": [
        "s3:ListBucket"
      ],
      "Resource": "arn:aws:s3:::YOUR-BUCKET-NAME"
    },
    {
      "Sid": "UploadObjects",
      "Effect": "Allow",
```

```
"Action": [  
  "s3:PutObject"  
],  
"Resource": "arn:aws:s3:::YOUR-BUCKET-NAME/*"  
}  
]  
}
```

Replace:

YOUR-BUCKET-NAME

with your actual bucket name.

For example:

arn:aws:s3:::swiggy-files-2026-yourname

and:

arn:aws:s3:::swiggy-files-2026-yourname/*

Important Security Point

Do not add these permissions:

s3:DeleteObject

s3:GetObject

Step 3: Attach the Policy

After creating the policy:

1. Go to IAM → Users.
2. Select zomatoUploader.
3. Add permissions.
4. Attach the custom policy you created.

Task 4: Test the IAM Permissions

Test 1: List Files

- Try to view/list the bucket contents.

Expected result:

- Allowed

Reason:

- s3:ListBucket
- has been granted.

Test 2: Upload a File

Try uploading a new test file.

Expected result:

- Allowed

Reason:

- s3:PutObject
- has been granted.

Test 3: Download a File

Try to download an existing object.

Expected result:

- Denied

Reason:

The policy does not grant:

- s3:GetObject

Test 4: Delete a File

Try to delete an existing test object.

Expected result:

- Denied

Reason:

The policy does not grant:

- s3:DeleteObject

Task 5: Importance of IAM Roles and Policies

IAM roles and policies help protect user data in cloud applications such as Paytm or PhonePe by controlling which users, applications, and services can access sensitive resources.

For example, an application server may need permission to store transaction logs in an S3 bucket but should not have permission to delete customer records or access unrelated databases. IAM policies can provide only the permissions required for that specific task.

IAM roles are especially useful for AWS services and applications because they can provide temporary credentials instead of requiring applications to store long-term AWS access keys.

Least Privilege

The principle of least privilege means that every user, application, and service should receive only the permissions necessary to perform its required tasks.

This reduces the potential impact if an account or application is compromised.

Real-World Security Risk

If IAM is configured incorrectly, an unauthorized user or compromised application could receive excessive permissions.

For example, if an S3 bucket containing customer documents were accidentally accessible to an overly privileged identity, an attacker who compromised that identity could potentially read, modify, or delete sensitive information.

Therefore, organizations should use:

- Least-privilege policies
- Strong authentication
- MFA where appropriate
- Regular permission reviews
- Monitoring and logging
- Separate roles for different applications and services